Ruta de Aprendizaje de Ciberseguridad: De la Base Cero al Dominio de la Seguridad Ofensiva y Forense Digital

Fundamentos de Tecnologías de la Información y Arquitectura de Redes

El desarrollo del pensamiento analítico en ciberseguridad requiere, de manera ineludible, una base sólida en el funcionamiento interno de las tecnologías de la información[1]. Un error común consiste en intentar dominar las técnicas de intrusión o análisis forense sin comprender previamente la infraestructura subyacente[1]. Los sistemas y los datos no existen de forma aislada; se comunican mediante protocolos específicos que deben entenderse a nivel de bits antes de intentar manipularlos o investigarlos[2].

Redes de Computadoras y la Pila de Protocolos TCP/IP

La comunicación digital se rige por el modelo conceptual de interconexión de sistemas abiertos (OSI) y la suite de protocolos de internet (TCP/IP)[3]. Para analizar las vulnerabilidades o reconstruir un ataque, se debe dominar el flujo de datos a través de estas capas[3].
Para calcular las dimensiones de una subred y el rango de direccionamiento IP disponible en un entorno de red, se aplica la siguiente formulación matemática basada en la notación CIDR (Classless Inter-Domain Routing)[1]:

$$H = 2^{32-P} - 2$$

Donde P representa la longitud de la máscara de subred en bits (prefijo CIDR) y H representa la cantidad total de direcciones IP de hosts utilizables dentro de ese segmento[1]. Se restan dos direcciones debido a la reserva obligatoria de la dirección de red (donde todos los bits de host son cero) y la dirección de difusión o *broadcast* (donde todos los bits de host son uno)[7].
La interacción entre estos protocolos durante un flujo de navegación web estándar sigue un orden lógico riguroso[3]:

Paso	Componente de Red	Protocolo / Mecanismo Principal	Descripción del Flujo y Eventos de Red

1	Cliente / Resolución	DNS (Domain Name System)[3]	El host traduce el nombre de dominio (ej. seguridad.local) en una dirección IP consultando al servidor DNS configurado[3].
2	Establecimiento	TCP (Transmission Control Protocol)[3]	Se inicia un acuerdo de tres vías (*Three-Way Handshake*): envío de bandera SYN, respuesta SYN-ACK y confirmación final ACK[3].
3	Seguridad	TLS (Transport Layer Security)[3]	Se negocian algoritmos de cifrado y se intercambian certificados digitales para asegurar la confidencialidad e integridad del canal[3].
4	Aplicación	HTTP (Hypertext Transfer Protocol)[3]	El cliente transmite una petición (ej. GET /index.html) y el servidor procesa y responde con los recursos solicitados y códigos de estado (ej. 200 OK)[3].
5	Enrutamiento	IP (Internet Protocol)	Los enrutadores de la red leen las direcciones de origen y destino de

			la capa de red para dirigir los paquetes individualmente[5].

Administración del Sistema y Estructura del Kernel de Linux y Windows

La línea de comandos es la herramienta principal del analista de seguridad[1]. En entornos basados en el kernel de Linux, es necesario adquirir destreza en la manipulación y búsqueda de patrones de texto directamente desde la terminal[1]. El análisis de registros (*logs*) de auditoría se agiliza significativamente mediante el uso combinado de tuberías (|) y utilidades de procesamiento de texto como grep, awk y sed[3].
Por ejemplo, para filtrar intentos de autenticación fallidos en un servidor Linux, se puede ejecutar:

```bash
grep "Failed password" /var/log/auth.log | awk '{print $11}' | sort | uniq -c
```

Este comando busca coincidencias en el archivo de logs de autenticación, aísla la columna que contiene la dirección IP de origen, la ordena y genera un recuento estadístico que permite identificar ataques de fuerza bruta en curso.
En sistemas operativos Windows, el analista debe comprender el funcionamiento de los procesos internos del sistema y las estructuras del Administrador de Cuentas de Seguridad (SAM) y el Active Directory[4]. Windows mantiene una estructura de árbol de procesos altamente predecible[10]. Cualquier desviación de esta genealogía normal (por ejemplo, el proceso de subsistema de autoridad de seguridad local lsass.exe ejecutándose como hijo de un navegador web o un procesador de comandos cmd.exe) constituye un indicador inmediato de compromiso[10].

Diseño e Implementación de Laboratorios de Práctica Aislados

La ciberseguridad es una disciplina eminentemente práctica[1]. El dominio de las herramientas y tácticas de ataque y defensa solo se logra mediante la experimentación directa[13]. Sin embargo, la realización de estas pruebas en redes de producción o sistemas no autorizados es ilegal y peligrosa[2]. La solución estándar en la industria es el despliegue de un laboratorio virtual aislado[5].

Guía de Despliegue de Oracle VirtualBox

Para iniciar la infraestructura, se descarga Oracle VirtualBox desde el sitio oficial e ingresa a la configuración del BIOS/UEFI de la máquina física (*host*) para asegurar la activación de las tecnologías de virtualización de hardware (Intel VT-x o AMD-V)[15].
Una vez instalado el hipervisor, se procede a configurar las interfaces de red virtualizadas[15]:

1. Se abre VirtualBox y se selecciona *Archivo > Herramientas > Administrador de redes de red*.
2. Se crea una nueva red NAT (*NAT Network*), asignando un direccionamiento IPv4 como 10.0.2.0/24. Esta configuración proporciona conectividad a internet de manera segura a las máquinas virtuales, ocultando sus direcciones IP detrás de la interfaz del host y manteniéndolas aisladas de la red local física[5].
3. Para un aislamiento más estricto, se puede configurar una interfaz de Red Interna (*Internal Network*). Esto impide cualquier tráfico hacia o desde el equipo físico host, bloqueando la salida a internet y limitando la comunicación exclusivamente a las máquinas virtuales asignadas a dicho canal.

Proceso de Aprovisionamiento de Máquinas Virtuales

Un entorno de entrenamiento básico requiere al menos un sistema atacante y un objetivo vulnerable[15].

Configuración de la Máquina Atacante (Kali Linux)

Se descarga la plantilla preconfigurada en formato OVA para VirtualBox desde el sitio de Kali Linux para ahorrar tiempo de instalación[15].

1. En VirtualBox, se selecciona *Archivo > Importar servicio virtualizado*, se elige el archivo OVA descargado y se procede con la importación[15].
2. Se accede a la configuración de la máquina virtual importada y se asignan al menos 4096 MB de memoria RAM y 2 núcleos de procesador virtual para un rendimiento óptimo[15].
3. En la sección de *Red*, se asocia el adaptador al perfil de la "Red NAT" previamente configurada[5].
4. Se arranca la máquina virtual, se inicia sesión con las credenciales por defecto (kali / kali) y se actualiza el sistema operativo ejecutando en terminal[15]:
   Bash
   ```
   sudo apt update && sudo apt upgrade -y
   ```
5. Tras completarse la actualización, se apaga la máquina virtual y se crea una instantánea (*snapshot*) limpia de respaldo en VirtualBox, permitiendo revertir el estado del sistema a este punto en caso de daños futuros[15].

Configuración de un Objetivo Vulnerable de Práctica (Metasploitable 2)

Metasploitable 2 es una distribución Linux diseñada intencionadamente con múltiples configuraciones inseguras y servicios vulnerables listos para auditorías[5].

1. Se descarga el archivo comprimido del sistema desde SourceForge y se extrae el archivo

de disco virtual (.vmdk)[15].

2. En VirtualBox, se crea una nueva máquina virtual seleccionando *Tipo: Linux* y *Versión: Linux de 64 bits*. Se asignan 512 MB de memoria RAM[15].
3. En la sección de *Disco Duro*, se opta por la opción "Usar un archivo de disco duro virtual existente" y se asocia el archivo .vmdk previamente extraído[15].
4. Se cambia el adaptador de red de la máquina virtual al perfil de la "Red NAT", garantizando que esté en el mismo segmento lógico de red que la máquina Kali Linux[5].

Despliegue de un Controlador de Dominio Active Directory Vulnerable

Para emular entornos de redes corporativas, es indispensable simular la suite de servicios de Microsoft Windows[9].

1. Se descarga la imagen ISO de evaluación de Windows Server (por ejemplo, versión 2019 o 2022) desde el Microsoft Evaluation Center[18].
2. Se crea una nueva máquina virtual en VirtualBox, asignándole al menos 2048 MB de RAM y un disco de expansión dinámica (formato VDI) de al menos 40 GB[18].
3. Se monta el archivo ISO en la unidad de almacenamiento virtual de la máquina virtual y se procede a iniciar la instalación del sistema seleccionando la edición con "Experiencia de Escritorio"[18].
4. Una vez instalado, se le asigna una dirección IP estática al adaptador de red virtual dentro de la interfaz del sistema operativo (por ejemplo, 10.0.2.10).
5. En el *Administrador del Servidor*, se selecciona la opción *Agregar roles y características* e instala el servicio de **Active Directory Domain Services (AD DS)**[17].
6. Tras completar la instalación del rol, se hace clic en el menú de notificaciones y se selecciona *Promover este servidor a controlador de dominio*, configurando un nuevo bosque con un dominio interno local (ej. empresa.local)[17].
7. Tras el reinicio del servidor, se utiliza el Administrador de Usuarios y Equipos de Active Directory o un script de automatización de PowerShell para generar cuentas de usuario ficticias con contraseñas intencionalmente débiles para permitir ataques de diccionario futuros[17].

Curso Intensivo de Hacking Ético y Pruebas de Penetración (Pentesting)

Las pruebas de penetración se ejecutan de manera sistemática siguiendo metodologías aceptadas por la industria (como PTES o OWASP)[2]. El éxito de una intrusión ética radica en la rigurosidad de las fases de recolección de información, análisis de vulnerabilidades y explotación precisa[2].

Reconocimiento y Escaneo con Nmap

El escaneo de puertos permite identificar la superficie de ataque expuesta de un host objetivo[2]. Nmap realiza esto mediante el envío de paquetes estructurados a nivel de transporte TCP/UDP[2].

Escaneo de Puertos TCP con Bandera SYN (Half-Open Scan)

Este tipo de escaneo es el estándar debido a su rapidez y menor intrusividad, ya que no llega a completar una conexión TCP de tres vías.
El proceso de escaneo y la interacción de paquetes se realiza siguiendo estas fases lógicas:



1. El atacante transmite un paquete TCP con la bandera SYN activa hacia un puerto específico del host objetivo[7].
2. Si el puerto se encuentra abierto y a la escucha, el servidor objetivo devuelve un paquete TCP con las banderas SYN y ACK activas[7].
3. El host atacante procesa la respuesta e interrumpe de inmediato el proceso de conexión enviando un paquete con la bandera RST activa, evitando así que el servicio registre una conexión establecida completa.
4. Si el puerto del servidor objetivo se encuentra cerrado, este responderá con un paquete con las banderas RST y ACK activas, indicando la indisponibilidad del servicio[7].

Un comando estándar para la enumeración detallada en un entorno de pruebas se ejecuta de la siguiente forma:

```bash
nmap -sS -p- -sV -sC -T4 -Pn 10.0.2.15 -oN escaneo_inicial.txt
```

- -sS: Indica la realización de un escaneo de tipo TCP SYN[7].
- -p-: Fuerza el escaneo de la totalidad de los 65,535 puertos TCP existentes[2].
- -sV: Activa la sonda de versiones de servicios para identificar la aplicación específica

detrás de cada puerto abierto[2].

- -sC: Ejecuta una selección de scripts automatizados por defecto del motor NSE para buscar fallos comunes conocidos[2].
- -T4: Establece la velocidad del temporizador de transmisión en un nivel optimizado para entornos de red estables[2].
- -Pn: Desactiva el ping de descubrimiento preliminar (ICMP Echo Request), asumiendo que el host objetivo se encuentra encendido (evadiendo bloqueos básicos de cortafuegos)[7].
- -oN escaneo_inicial.txt: Guarda la salida del escaneo en formato de texto plano para documentación.

Pruebas de Seguridad en Aplicaciones Web con Burp Suite

Las aplicaciones web se auditan analizando la estructura de las peticiones que se envían al servidor y evaluando cómo se procesan las respuestas[21].

Guía Paso a Paso para Identificar una Vulnerabilidad de IDOR (Insecure Direct Object Reference) con el Módulo Repeater

Una vulnerabilidad IDOR ocurre cuando una aplicación expone una referencia directa a un objeto interno de la base de datos sin validar si el usuario solicitante posee los permisos de autorización requeridos[23].

1. Se abre Burp Suite, se accede a la pestaña *Proxy* > *Intercept* y se hace clic en *Open Browser* para iniciar el navegador web embebido de Burp[21].
2. En el navegador web, se inicia sesión en la aplicación web objetivo utilizando una cuenta de prueba (ej. usuario_cliente_A)[23].
3. Se accede a la sección de consulta de perfil o facturación. Al realizar la acción, Burp Suite interceptará la petición HTTP correspondiente[21]. El analista examinará la petición, observando una estructura similar a:
   ```
   HTTP
   GET /api/v2/billing/invoices/INV-2026-00142 HTTP/1.1
   Host: app.acmesaas.io
   Cookie: session=eyJ1c2VySWQiOiIxNDIifQ==
   Authorization: Bearer jwt_token_here
   ```
4. Se hace clic derecho sobre el texto de la petición dentro de Burp Suite y se selecciona la opción **Send to Repeater**[21].
5. En la pestaña de *Repeater*, se edita manualmente la dirección URI de la petición, modificando el identificador del recurso de INV-2026-00142 a INV-2026-00098 (un identificador que pertenece a otro cliente de la plataforma)[21].
6. Se hace clic en el botón **Send**[21].
7. Se evalúa la respuesta HTTP devuelta por el servidor[21]. Si la aplicación responde con un código de estado 200 OK y devuelve el contenido de la factura de un tercero en el cuerpo del mensaje, se confirma la presencia de una vulnerabilidad de IDOR de alta

criticidad por la falta de controles de autorización[23].

Guía Paso a Paso para un Ataque de Fuerza Bruta en Formularios de Autenticación con el Módulo Intruder

El módulo *Intruder* se especializa en automatizar el envío masivo de payloads sobre peticiones HTTP estructuradas[21].

1. En el navegador de Burp Suite, se accede al formulario de login de la aplicación, ingresando credenciales arbitrarias (ej. usuario admin y contraseña password123)[24].
2. En la pestaña de *Proxy > HTTP History*, se localiza la petición de tipo POST enviada hacia /login, se hace clic derecho sobre ella y se selecciona **Send to Intruder**[24].
3. Se accede a la pestaña de *Intruder > Positions*. Se borran los marcadores automáticos definidos por Burp[25].
4. Se selecciona la cadena de texto correspondiente al valor de la contraseña (en este caso, password123) y se hace clic en el botón **Add §** para configurar esa posición como la variable que recibirá las cargas de ataque[24]. Se verifica que la tipología del ataque esté configurada en **Sniper**[25].
5. Se accede a la pestaña de *Intruder > Payloads*. En la configuración de la lista, se mantiene seleccionada la opción de *Simple List*[24].
6. En el cuadro de texto inferior, se copian y pegan las palabras de un diccionario de contraseñas comunes (como una porción de la lista rockyou.txt) o se ingresan valores manuales de prueba[24].
7. Se hace clic en el botón **Start Attack** en la esquina superior derecha[24].
8. En la ventana de monitoreo del ataque, se evalúan las respuestas comparando la longitud de los datos retornados (*Length*) y los códigos de estado HTTP[24]. Una petición que devuelva un tamaño de respuesta significativamente diferente a las demás, o un código de redirección (ej. 302 Found o 200 OK con longitud anómala), revela la contraseña correcta que ha permitido eludir o acceder al sistema legítimamente[24].

Curso Intensivo de Análisis Forense Digital (DFIR)

La informática forense tiene como objetivo reconstruir eventos delictivos o intrusiones de manera rigurosa, de modo que la evidencia sea analíticamente infalible[26].

Adquisición y Análisis de Memoria RAM con Volatility 3

Los volcados de memoria volátil RAM capturan de manera única información confidencial que el atacante puede haber ocultado de los registros en disco, tales como claves criptográficas, malware de inyección directa e hilos de red en ejecución[11].

Adquisición Forense en Sistemas Windows

Para obtener un volcado de memoria de forma forensicamente segura desde una máquina Windows bajo sospecha de intrusión, se ejecuta una herramienta de línea de comandos privilegiada como **WinPmem**[12].

```
DOS
winpmem_mini_x64.exe -o C:\evidencias\captura_ram.raw
```

Este comando escribe el contenido físico completo de la memoria volátil directamente a un archivo de volcado plano (.raw), preservando el estado de ejecución del sistema operativo[12].

Ejecución del Workflow de Análisis Forense en RAM

Una vez transferida la captura de RAM (captura_ram.raw) a la estación de trabajo forense de Linux donde se encuentra instalado Volatility 3, se procede a su investigación secuencial para documentar el incidente[11].

Paso 1: Obtención de Datos de Identificación del Sistema

Antes de realizar búsquedas complejas, se recopilan los detalles generales del sistema operativo de origen[31].

```
Bash
python3 vol.py -f captura_ram.raw windows.info
```

Este plugin analiza las estructuras de datos de la cabecera del kernel del sistema operativo Windows y devuelve la versión exacta del kernel, el nivel de service pack, la arquitectura de procesador y la fecha y hora UTC exacta en que se extrajo el archivo de RAM, permitiendo establecer el huso horario de análisis[31].

Paso 2: Análisis de la Lista de Procesos en Ejecución

Se genera una vista tabular de todos los procesos que se encontraban activos en el sistema operativo durante la captura[11].

```
Bash
python3 vol.py -f captura_ram.raw windows.pslist
```

El analista debe inspeccionar la tabla buscando procesos que tengan nombres anómalos o que intenten suplantar procesos legítimos del sistema operativo (por ejemplo, buscar un proceso denominado svch0st.exe o ejecutándose de manera duplicada en un árbol no esperado)[11].

Paso 3: Identificación de Procesos Ocultos por Rootkits

Los rootkits avanzados pueden manipular las listas internas que lee el administrador de tareas de Windows para ocultar los procesos del malware[10].

```Bash
python3 vol.py -f captura_ram.raw windows.psscan
```

Este comando escanea de manera profunda la memoria buscando estructuras del kernel de tipo _EPROCESS que hayan sido desvinculadas de la lista de ejecución activa[11]. Si un identificador de proceso (PID) es visible en el reporte de psscan pero no se muestra en el listado convencional devuelto por pslist, se confirma la presencia de un binario malicioso oculto mediante técnicas evasivas a nivel de kernel[11].

Paso 4: Visualización de Relaciones de Procesos mediante Árboles

Para entender cómo se inició la amenaza en el sistema, se visualiza la genealogía completa de la ejecución[11].

```Bash
python3 vol.py -f captura_ram.raw windows.pstree
```

Este reporte organiza la salida mostrando qué proceso padre (PPID) inició cada proceso hijo (PID)[11]. Si se observa que el cliente de correo de la oficina (ej. outlook.exe) o el procesador de documentos de texto (ej. winword.exe) iniciaron una instancia del intérprete de comandos powershell.exe, esto constituye una confirmación de un compromiso inicial a través de documentos adjuntos maliciosos[12].

Paso 5: Inspección de Líneas de Comando Ejecutadas

Se recuperan los parámetros exactos con los que fue ejecutado cada proceso activo en el sistema[11].

```bash
python3 vol.py -f captura_ram.raw windows.cmdline
```

El analista inspecciona la salida buscando scripts embebidos en el inicio de la consola de comandos de Windows, buscando específicamente código ofuscado o cadenas Base64 largas que suelen ocultar scripts de malware fileless[11].

Paso 6: Análisis de Conexiones de Red en Memoria

Se extraen todos los sockets de comunicación y puertos abiertos activos o recientemente cerrados durante la adquisición[11].

```bash
python3 vol.py -f captura_ram.raw windows.netscan
```

El analista mapea las direcciones IP externas reportadas en las comunicaciones de red sospechosas en bases de datos globales de inteligencia de amenazas, identificando si los procesos del malware están comunicando datos hacia servidores de comando y control (C2) externos[11].

Paso 7: Detección de Inyecciones de Código en Memoria

El malware suele inyectar su código malicioso directamente en procesos legítimos que ya se encuentran autorizados (como explorer.exe) para evadir cortafuegos o antivirus locales[11].

```bash
python3 vol.py -f captura_ram.raw windows.malfind
```

Este comando busca páginas de memoria que posean propiedades de ejecución simultánea a nivel de permisos de protección (permisos PAGE_EXECUTE_READWRITE o RWX) y que no tengan un archivo físico ejecutable asociado en el disco duro[10]. Si el reporte devuelve marcas y

firmas asociadas a cabeceras ejecutables PE (MZ) en esas páginas, se documenta la inyección directa de código[11].

Paso 8: Extracción Forense del Archivo Malicioso

Tras identificar el proceso responsable o inyectado en el sistema (por ejemplo, con un ID de proceso PID: 4320), se extrae de la memoria RAM hacia la estación de análisis para su ingeniería inversa o firma antivirus[11].

```bash
python3 vol.py -f captura_ram.raw -o /home/forense/salida windows.dumpfiles --pid 4320
```

Este comando reconstruye y guarda la imagen completa de los archivos binarios asociados a ese proceso en el directorio especificado, permitiendo realizar análisis estáticos de hash contra bases de datos mundiales de malware[11].

Análisis Forense de Medios de Almacenamiento con Autopsy

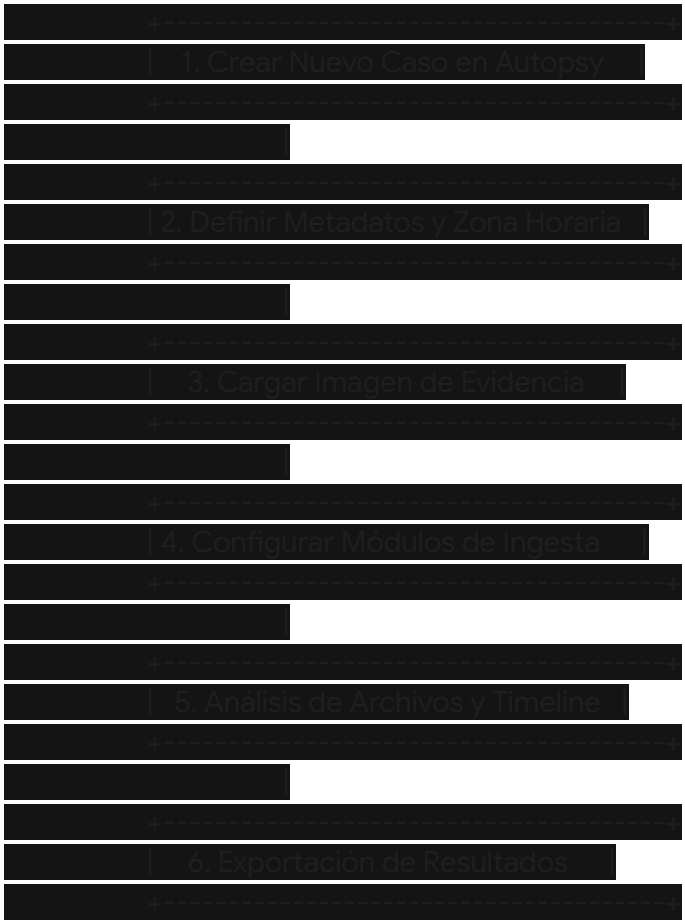
La investigación forense de discos duros y memorias físicas requiere metodologías rigurosas que impidan la manipulación accidental de la evidencia original[28]. Para validar la integridad absoluta de la imagen de disco original y asegurar su admisibilidad en procesos judiciales, se calcula su huella criptográfica SHA-256[34]. Se establece la siguiente formulación científica de concordancia de integridad[34]:

$$\text{SHA-256}(E_{\text{original}}) \equiv \text{SHA-256}(I_{\text{forense}})$$

Donde E_{original} representa el dispositivo físico de almacenamiento de evidencia incautado y I_{forense} representa la imagen forense bit a bit copiada del dispositivo en formato plano (RAW) o estructurado (E01)[35]. El analista debe verificar que el hash criptográfico calculado para ambos objetos sea equivalente de manera idéntica antes de iniciar cualquier proceso de inspección o ingesta de datos[34].

Guía Paso a Paso para un Análisis Completo en Autopsy

El software Autopsy proporciona un flujo de trabajo asistido para el análisis estructurado de imágenes de disco[34].



1. **Creación del Caso Forense:** Se inicia la aplicación Autopsy en la estación de investigación y se selecciona la opción *New Case*[34]. Se ingresa un nombre formal identificativo de la investigación, el directorio de salida seguro donde se guardará la base de datos local y los metadatos de control (Case Number, Nombre del Examinador Forense)[36].
2. **Configuración de la Zona Horaria:** En la ventana de configuración del caso, se define con precisión la zona horaria de visualización de las marcas de tiempo (por ejemplo, hora UTC o huso local del incidente)[36]. Este ajuste asegura que cuando Autopsy interprete los metadatos del sistema de archivos, las marcas temporales se traduzcan de manera precisa para reconstruir la cronología de eventos de forma fidedigna[36].
3. **Adición de la Fuente de Datos (Imagen de Evidencia):** Se avanza a la sección de *Data Source*[34]. Se selecciona la opción de *Disk Image or VM File* y se indica la ruta del archivo de imagen forense descargado (por ejemplo, formato .E01 o un disco virtual .vmdk de

laboratorio)[35].

4. **Configuración de los Módulos de Ingesta (Ingest Modules):** Los módulos de ingesta definen el tipo de análisis automatizado que ejecutará el backend de Autopsy[34]. Para optimizar el tiempo de procesamiento, se seleccionan los módulos pertinentes de forma manual[34]:
   - *Recent Activity:* Para extraer historiales web de los navegadores, cookies, dispositivos USB previamente conectados y accesos a archivos recientes[34].
   - *Hash Lookup:* Para cotejar firmas criptográficas de los archivos analizados contra listas de software seguro (NSRL) y contra hashes de amenazas conocidas en la industria[34].
   - *File Type Identification:* Para detectar tipos de archivos reales basándose en el análisis de las firmas internas de bytes (*magic numbers*), independientemente de las extensiones del nombre[34].
   - *Extension Mismatch Detector:* Para listar de forma inmediata archivos sospechosos cuyas firmas no corresponden a la extensión del archivo, táctica común utilizada para ocultar malware o datos robados[34].
   - *Keyword Search:* Para buscar palabras específicas de interés que involucren términos de la investigación (ej. contraseñas de cuentas, identidades o nombres de marcas confidenciales)[34].
5. **Ejecución y Análisis de Hallazgos:** Se inicia el proceso de indexación. Al finalizar el procesamiento, se inspeccionan las diferentes categorías en la consola del programa[34]:
   - *File Types > Documents:* Permite acceder y filtrar documentos de texto u hojas de cálculo manipuladas por el objetivo en la imagen[38].
   - *Deleted Files:* Permite inspeccionar carpetas e identificar archivos borrados por el usuario que aún permanecen guardados físicamente en los clústeres no asignados del disco[34]. Para extraer un archivo borrado, se hace clic derecho sobre el registro en Autopsy, se selecciona la opción **Extract File(s)** y se guarda en un directorio seguro de salida[34].
   - *Timeline Tool:* Permite reconstruir de forma cronológica interactiva cada evento documentado en el sistema de archivos (ej. creación de carpetas, modificación de configuraciones o ejecución de utilidades anti-forenses)[34]. Esta herramienta permite determinar exactamente qué archivos se alteraron durante la ventana de tiempo del incidente[34].
6. **Generación del Reporte:** Al finalizar la investigación, se selecciona la pestaña de *Generate Report*, configurando una salida en formato HTML o Excel que documente de forma fidedigna cada una de las evidencias encontradas y sus marcas temporales calculadas para la entrega al equipo legal de la organización[35].

Análisis de Tráfico de Red y Detección de Amenazas con Wireshark

El monitoreo del tráfico a nivel de paquetes permite identificar comportamientos maliciosos,

fugas de datos de red y diagnosticar anomalías de conectividad[8].

Guía de Flujo Práctico de Análisis con Filtros de Visualización de Wireshark

Para aislar tráfico malicioso en un archivo de captura de red extenso (captura.pcap), se aplica un flujo estructurado de triage analítico paso a paso[8]:



1. **Aislamiento de la Máquina Investigada:** El primer paso en el proceso consiste en limpiar el ruido de la red general aislando exclusivamente las interacciones del host sospechoso[8]:
   Fragmento de código
   ip.addr == 192.168.1.50

2. **Verificación de la Fase de Resolución DNS:** Se analiza si el dispositivo comprometido realizó consultas hacia dominios de internet inusuales[8]:
   Fragmento de código
   ```
   ip.addr == 192.168.1.50) and dns
   ```
   El analista inspecciona los nombres de dominio consultados[8]. Respuestas DNS que retornen códigos de error distintos de cero (por ejemplo, dns.flags.rcode != 0) sugieren intentos de conexión fallidos hacia dominios inactivos comúnmente utilizados en algoritmos de generación de dominios de malware (DGA)[8].
3. **Auditoría de Intentos de Conexión TCP:** Se evalúan los flujos de establecimiento de sesión TCP buscando anomalías de escaneo o denegación de servicio[7]:
   Fragmento de código
   ```
   ip.addr == 192.168.1.50) and (tcp.flags.syn == 1 and tcp.flags.ack == 0)
   ```
   Si el reporte muestra un gran volumen de paquetes SYN enviados hacia múltiples direcciones IP en cortos intervalos de tiempo y sin recibir respuestas de confirmación SYN-ACK, se documenta un escaneo de puertos activo o una agresión de tipo SYN Flood[7].
4. **Análisis de Solicitudes HTTP de Transmisión de Datos:** Se aíslan envíos de información web en texto plano que puedan contener credenciales de acceso[7]:
   Fragmento de código
   ```
   http.request.method == "POST"
   ```
   El analista examina el cuerpo de los datos transmitidos en estas peticiones para detectar contraseñas expuestas sin cifrar o intentos de inyección SQL dirigidos a aplicaciones externas[7].
5. **Detección de Fugas de Información o Tráfico C2 Encubierto:** Se aíslan protocolos de mensajería ICMP (comúnmente pings) para evaluar si se están utilizando como canales encubiertos de transmisión[7]:
   Fragmento de código
   ```
   icmp and frame.len > 150
   ```
   Dado que las tramas ICMP estándar son de pequeño tamaño, un paquete ICMP con un tamaño superior a 150 bytes sugiere el uso de técnicas de tunelización para exfiltrar datos del sistema saltándose las restricciones de cortafuegos de la red[7].
6. **Reconstrucción de Conversaciones Completas:** Una vez localizado un paquete sospechoso, se hace clic derecho sobre él dentro de la interfaz de Wireshark y se selecciona la opción *Follow > TCP Stream*[7]. Esto genera una reconstrucción de la conversación completa en orden cronológico, permitiendo leer exactamente los datos que interactuaron entre el atacante y la máquina de la red[7].

Elaboración de Informes Profesionales de Auditoría de

Ciberseguridad

El resultado final de cualquier auditoría de ciberseguridad, prueba de penetración o investigación forense es la entrega de un informe técnico[41]. Este informe representa la justificación y validez del trabajo del analista ante los responsables de la organización[42].

Redacción del Resumen Ejecutivo para la Dirección

El resumen ejecutivo debe redactarse en un estilo directo, formal y libre de jerga técnica excesiva[41]. Su objetivo es informar a los directores de la organización sobre la postura de riesgo de seguridad existente basándose en las implicaciones que tienen las vulnerabilidades descubiertas en la continuidad y los activos del negocio[41].

Para estructurar los riesgos detectados, se recomienda diseñar una matriz de criticidad que use métricas estandarizadas como el sistema de puntuación de vulnerabilidades comunes (CVSS v3.1)[23]:

ID de Vulnerabilidad	Nombre del Hallazgo	CVSS v3.1	Severidad	Impacto en el Negocio	Esfuerzo de Corrección
CS-2026-001	IDOR en API de Facturación[23]	9.1[23]	Crítica[23]	Exposición no autorizada de registros financieros y datos personales[23].	Medio (Ajuste de código)
CS-2026-010	Autenticación Rota en Refresh Token[23]	7.5[23]	Alta[23]	Acceso persistente no autorizado a cuentas de clientes del sistema[23].	Bajo (Ajuste de lógica)
CS-2026-022	Contraseña por Defecto en Servicios AD	8.8	Alta	Acceso no autorizado a nivel de dominio y	Bajo (Cambio de directivas)

				control de la infraestructura[9].	
CS-2026-035	Falta de Cifrado en Transferencia de Archivos	5.3	Media	Exposición y captura de credenciales por escucha en red de área local[3].	Alto (Migración de protocolo)

Formato Formal para Fichas de Hallazgos Técnicos

Cada hallazgo de vulnerabilidad documentado en el cuerpo principal del reporte debe seguir una estructura estandarizada que permita a los equipos de desarrollo e ingeniería reproducir y corregir el fallo[41].

[redacted]

"refresh_token": "token_stolen_value"

3. El servidor procesa la petición de forma insegura sin verificar la validez del token anterior.
4. Adjuntar la captura de pantalla o volcado de logs que demuestre la obtención de un token nuevo [cite: 23, 41, 43].

IMPACTO SOBRE EL NEGOCIO:
Explicación detallada de las repercusiones operativas y financieras que se desprenden del compromiso exitoso de este fallo por parte de un atacante (ej. acceso no autorizado, manipulación de datos confidenciales o caída del servicio) [cite: 23, 41, 43].

GUÍA DE REMEDIACIÓN DETALLADA:
Sección instructiva que ofrece el método recomendado para mitigar la vulnerabilidad, proporcionando si es posible fragmentos de código seguros o parámetros de configuración [cite: 23, 41, 43, 44].

Código seguro recomendado (Ejemplo en JavaScript/Node.js):
```
const verifyRefreshToken = async (req, res) => {
  const { refreshToken } = req.body;
  const tokenRecord = await db.tokens.findOne({ token: refreshToken });
  if (!tokenRecord || tokenRecord.isExpired || tokenRecord.isRevoked) {
    return res.status(401).json({ error: "Token de refresco inválido o expirado" });
  }
  // Procesar generación segura de nuevo token...
}
```

Plan Estratégico de Formación y Certificaciones de la Industria

El desarrollo profesional en ciberseguridad se beneficia enormemente de la obtención de certificaciones reconocidas por la industria[1]. Sin embargo, se debe evitar el error de coleccionar certificaciones teóricas sin poseer un respaldo de habilidades prácticas reales que las sustenten[1]. Las certificaciones actúan como un mecanismo de validación de las destrezas adquiridas en laboratorio ante las organizaciones de selección[1].
Un itinerario progresivo de estudio y especialización se estructura en las siguientes fases formativas[27]:

Etapa Formativa	Enfoque de Estudio Tecnológico	Certificación Objetivo Sugerida	Justificación e Impacto Profesional
Fase 1: Inicial	Fundamentos de tecnologías de la información, administración de sistemas y conceptos introductorios de seguridad[1].	**CompTIA Security+**[1] / **eJPT**[1]	Establece un vocabulario común del sector y valida destrezas básicas requeridas para roles de soporte técnico avanzados o SOC Junior[1].
Fase 2: Especialización	Operación de herramientas de escaneo y análisis defensivo de logs y monitoreo[2].	**CompTIA PenTest+**[5] / **CompTIA CySA+**[5]	Valida habilidades para la realización de evaluaciones de vulnerabilidad estructuradas y el análisis de telemetría de seguridad[5].
Fase 3: Avanzada (Pentesting)	Explotación avanzada, escalada de privilegios y ataques Kerberos en Active Directory[9].	**OSCP** (Offensive Security Certified Professional)[4]	El estándar de oro práctico para auditorías de seguridad ofensivas, requiriendo completar exámenes prácticos de intrusión de 24 horas[5].
Fase 4: Avanzada (Forense)	Procesamiento de evidencias digitales, análisis avanzado de registros en sistemas de archivos y análisis de RAM[11].	**CHFI** (Computer Hacking Forensic Investigator)[26] / **GIAC GCIH**[47]	Valida destrezas forenses profundas y la capacidad técnica para actuar como analista de respuesta a incidentes en corporativos[27].

Fase 5: Experto	Simulación adversarial compleja (Red Teaming), evasión de defensas corporativas y arquitectura estratégica[27].	**SANS GIAC GCFA**[26] **/ eWPTX / CPENT**[27]	Acredita un nivel experto para liderar equipos técnicos de intrusión compleja o coordinar investigaciones forenses globales ante incidentes[27].

Conclusiones

La consolidación de un perfil profesional sólido en ciberseguridad exige una dedicación diaria y disciplinada orientada a la práctica empírica[14]. La ciberseguridad es una disciplina técnica viva; los vectores de explotación, los componentes de software y las técnicas ofensivas y defensivas evolucionan con gran rapidez, lo que requiere un compromiso constante con el aprendizaje continuo[13]. No se puede alcanzar un nivel de experto mediante atajos teóricos o la simple memorización de comandos de herramientas específicas[2]. El verdadero analista de ciberseguridad debe centrar sus esfuerzos en comprender los principios y mecanismos internos sobre los cuales operan los protocolos de comunicación y los sistemas operativos[2]. La estrecha relación analítica entre el hacking ético y el análisis forense digital se convierte en el mayor activo de un especialista[39]. Mientras que el conocimiento táctico de las metodologías de intrusión y explotación permite a los investigadores forenses anticipar la ruta lógica utilizada por los atacantes y localizar de manera ágil los artefactos residuales en disco y memoria, la comprensión minuciosa de las metodologías de respuesta a incidentes y preservación de evidencias proporciona a los profesionales ofensivos un nivel superior de control, rigurosidad y precisión técnica durante sus auditorías[11]. El dominio operativo de ambos mundos, sumado a la capacidad para estructurar y reportar de forma profesional el impacto de los hallazgos técnicos en los procesos críticos de la organización, constituye el factor de éxito definitivo para liderar la mitigación de los riesgos tecnológicos contemporáneos[41].

Obras citadas

1. Cybersecurity Roadmap for Beginners in 2026 (Step-by-Step) - Medium, https://medium.com/@Cyberking.pk/cybersecurity-roadmap-for-beginners-in-2026-step-by-step-b4584e59c68e
2. The Complete Ethical Hacking Learning Roadmap - NovelVista, https://assets.novelvista.com/resources/pdf/blogs/other/ethical-hacking-learning-roadmap.pdf
3. Ethical Hacking Learning Roadmap: From Beginner to Expert (2026) - Coursera, https://www.coursera.org/resources/ethical-hacking-learning-roadmap
4. Ethical Hacking - roadmap.sh, https://roadmap.sh/r/ethical-hacking-yyvh9
5. Cybersecurity Roadmap 2026: Breaking Into Cyber — Complete Guide - Cover6

Solutions, https://www.cover6solutions.com/breaking-into-cybersecurity-the-2026-complete-roadmap/
6. Step-by-Step Roadmap to Become an Ethical Hacker - NareshIT, https://nareshit.com/blogs/step-by-step-roadmap-to-become-an-ethical-hacker
7. Free Wireshark Display Filter Cheatsheet — 80+ Filters for DDoS & Network Analysis, https://flowtriq.com/tools/wireshark-filters
8. Wireshark Filters Cheat Sheet for Fast Packet Analysis - Code Labs Academy, https://codelabsacademy.com/en/blog/wireshark-filters-cheat-sheet/
9. Your Complete Roadmap to Starting Ethical Hacking in 2026: A Practical Guide for Beginners | by Narayan Regmi | Medium, https://pawan7.medium.com/your-complete-roadmap-to-starting-ethical-hacking-in-2026-a-practical-guide-for-beginners-d850021dc0d2
10. Volatility 3 Threat Detection Guide | PDF - Scribd, https://www.scribd.com/document/979979279/volatility3-cheatsheet
11. Memory Forensics for Beginners: A Practical Guide Using Volatility 3 (Windows) - Medium, https://medium.com/@sidhantchaurasiya12/memory-forensics-for-beginners-a-practical-guide-using-volatility-3-windows-133758bd92ee
12. Memory Forensics with Volatility 3: What Attackers Leave Behind - Hive Security, https://hivesecurity.gitlab.io/blog/memory-forensics-volatility-attack-detect/
13. How roadmap.sh Cyber Security Can Accelerate Your Ethical Hacking Journey - ONES.com, https://ones.com/blog/roadmap-sh-cyber-security-accelerate-ethical-hacking-journey/
14. Ethical Hacking Roadmap for Beginners (2026 Guide) - Hackercool Magazine, https://hackercoolmagazine.com/ethical-hacking-roadmap-for-beginners-2026-guide/
15. How to Set Up a Free Cybersecurity Home Lab (That Actually Teaches You Real Skills), https://medium.com/@saintsadiq/how-to-set-up-a-free-cybersecurity-home-lab-that-actually-teaches-you-real-skills-553910c7770e
16. Building a Security Lab in VirtualBox - 0xBEN, https://benheater.com/building-a-security-lab-in-virtualbox/
17. Home Lab Running Active Directory (Oracle VirtualBox) | Add Users w/PowerShell - GitHub, https://github.com/spooky7777/Home-Lab-Active-Directory
18. Building an Active Directory Pentesting Home Lab in VirtualBox - DEV Community, https://dev.to/adamkatora/building-an-active-directory-pentesting-home-lab-in-virtualbox-53dc
19. How to Build a Cybersecurity HomeLab - OffSec, https://www.offsec.com/blog/cybersecurity-homelab/
20. Ethical Hacking Roadmap: All You Need to Know About - The Knowledge Academy, https://www.theknowledgeacademy.com/blog/ethical-hacking-roadmap/
21. Burp Suite Tutorial: Intercepting, Modifying & Scanning HTTP Traffic - Pynt,

https://www.pynt.io/learning-hub/burp-suite-guides/burp-suite-tutorial-intercepting-modifying-scanning-http-traffic
22. Burp Suite for Penetration Testing of Web Applications - EC-Council, https://www.eccouncil.org/cybersecurity-exchange/penetration-testing/burp-suite-penetration-testing-web-application/
23. Sample Pentest Report | Ungated SOC 2 + ISO 27001 Format - Cybersecify, https://cybersecify.com/sample-report/
24. Using Burp to Brute Force a Login Page - PortSwigger, https://portswigger.net/support/using-burp-to-brute-force-a-login-page
25. Getting started with Burp Intruder - PortSwigger, https://portswigger.net/burp/documentation/desktop/tools/intruder/getting-started
26. DFIR Career Development Roadmap | PDF - Scribd, https://www.scribd.com/document/935099595/DFIR-Learning-Roadmap
27. Digital Forensics Career Path: Skills & Certifications - EC-Council, https://www.eccouncil.org/digital-forensics-career-path/
28. Forensic autopsy - apmla, https://www.theapmla.net/files/PEX02_Forensic%20Autopsy%20Manual.opt.pdf
29. Title: Volatility 3 Will Change How You Hunt Malware (and Here's the Cheatsheet) - SOCFortress, https://socfortress.medium.com/title-volatility-3-will-change-how-you-hunt-malware-and-heres-the-cheatsheet-a535d4530611
30. Volatility: A Beginner's guide to Memory Forensics - Hackercool Magazine, https://hackercoolmagazine.com/volatility-a-beginners-guide-to-memory-forensics/
31. Memory Forensics with Volatility 3 Lab | PDF | Malware - Scribd, https://www.scribd.com/document/925187758/DF-Lab11
32. How to Use Volatility for Memory Forensics and Analysis - Varonis, https://www.varonis.com/blog/how-to-use-volatility
33. Volatility 3 Windows Commands Cheat Sheet | PDF - Scribd, https://www.scribd.com/document/774365567/Cheatsheet-Volatility-v3
34. Analysis of Data Source Using Autopsy - GeeksforGeeks, https://www.geeksforgeeks.org/techtips/analysis-of-data-source-using-autopsy/
35. Autopsy | TryHackMe — Walkthrough | by jcm3 - Medium, https://medium.com/@jcm3/autopsy-tryhackme-walkthrough-f6ac929fd4ca
36. Autopsy Tool Forensic Analysis Guide | PDF | Computer File - Scribd, https://www.scribd.com/document/981988489/Case-study-1-2
37. Solving Digital Crime Scenes with Autopsy: A Hands-On Forensics Investigation - Medium, https://medium.com/@jibranhanan6/solving-digital-crime-scenes-with-autopsy-a-hands-on-forensics-investigation-9054c48a0c39
38. Autopsy Forense Digital: Tutorial Completo Paso a Paso (Caso Real Incluido) - YouTube, https://www.youtube.com/watch?v=gWclBdzBzDM
39. How I Study DFIR Every Day — My Routine, Tools, and Mindset | by seif - Medium, https://medium.com/@seiferboado101/how-i-study-dfir-every-day-my-routine-t

ools-and-mindset-42e9950061e6
40. Wireshark Cheatsheet - Black Hills Information Security, Inc., https://www.blackhillsinfosec.com/wireshark-cheatsheet/
41. Penetration Testing Report: Free Template and Guide - UnderDefense, https://underdefense.com/blog/penetration-testing-report-free-template-and-guide/
42. Report Writing — Professional Pentest Reports - Networkers Home, https://www.networkershome.com/fundamentals/ethical-hacking/report-writing-professional-pentest-reports/
43. The Definitive Guide to Cybersecurity Report Writing | by TheP3@rl | Medium, https://thep3arl.medium.com/the-definitive-guide-to-cybersecurity-report-writing-eec1cb0e230d
44. Free penetration testing report templates for OSCP exams, web app pentests, network assessments, and more. DOCX and PDF format. - GitHub, https://github.com/MSaiRam10/pentest-report-templates
45. Penetration Test Report Template | Cybersecurity Academy 101 - Graduate America, https://ga.edu/learn/academy/cybersecurity/pentest-report-template
46. Cybersecurity Roadmap 2026: Skills & Jobs by Hackersprey, https://www.hackersprey.com/blog/cybersecurity-roadmap-2026
47. Cybersecurity Career Roadmap for SOC, DFIR, and Incident Response, https://sethenoka.com/cybersecurity-career-roadmap/
48. Cybersecurity Certification Roadmap 2026: From Beginner to Security Expert - EC-Council, https://www.eccouncil.org/cybersecurity-exchange/ethical-hacking/cybersecurity-certification-roadmap/
49. Digital forensic (DFIR) specialist roadmap. - GitHub, https://github.com/Yousha/DFIR-Specialist-Roadmap